OFFSIDE LABS

Dynamic AMM

Release 0.5.7

Smart Contract Security Assessment

October 2026

Prepared for:

Meteora

Prepared by:

Offside Labs

Sirius Xie

Contents

1 About Offside Labs **2**

2 Executive Summary **3**

3 Summary of Findings **5**

4 Key Findings and Recommendations **6**

4.1 Unauthorized Redemption of Permanently Locked LP Tokens 6

5 Disclaimer **8**

1 About Offside Labs

Offside Labs is a leading security research team, composed of top talented hackers from both academia and industry.

We possess a wide range of expertise in modern software systems, including, but not limited to, *browsers*, *operating systems*, *IoT devices*, and *hypervisors*. We are also at the forefront of innovative areas like *cryptocurrencies* and *blockchain technologies*. Among our notable accomplishments are remote jailbreaks of devices such as the **iPhone** and **PlayStation 4**, and addressing critical vulnerabilities in the **Tron Network**.

Our team actively engages with and contributes to the security community. Having won and also co-organized *DEFCON CTF*, the most famous CTF competition in the Web2 era, we also triumphed in the **Paradigm CTF 2023** within the Web3 space. In addition, our efforts in responsibly disclosing numerous vulnerabilities to leading tech companies, such as *Apple*, *Google*, and *Microsoft*, have protected digital assets valued at over **$300 million**.

In the transition towards Web3, Offside Labs has achieved remarkable success. We have earned over **$9 million** in bug bounties, and **three** of our innovative techniques were recognized among the **top 10 blockchain hacking techniques of 2022** by the Web3 security community.

 **https://offside.io/**

 **https://github.com/offsidelabs**

 **https://twitter.com/offside_labs**

2 Executive Summary

Introduction

Offside Labs completed a security audit of *Dynamic AMM* smart contracts, starting on October 13th, 2026, and concluding on October 14th, 2026.

Project Overview

Meteora DAMM Release 0.5.6 and 0.5.7 introduces internal pool LP supply accounting. These values support liquidity operations, locked liquidity fees, swaps, and pool information. The changes also require LP token account owners to authorize withdrawals, validate tracked supply against mint supply, and require zero tracked pool supply for liquidity bootstrapping. Pool and vault account definitions are updated without increasing their sizes.

Audit Scope

The assessment scope contains mainly the smart contracts of the amm program for the *Dynamic AMM* project.

The audit is based on the following specific branches and commit hashes of the codebase repositories:

- Dynamic AMM
  - Codebase: `https://github.com/MeteoraAg/meteora-dynamic-amm`
  - Release 0.5.6
    - Codebase Link: `PR-224`
    - Commit Hash: eed2d45d78b0c71c9d092a084720f5c71d30955c
  - Release 0.5.7
    - Codebase Link: `PR-225`
    - Commit Hash: d0de75858b140f5476c9fac59a3eb9f1bc20eb84

The issues described in this report have been resolved by the following commit:

- Dynamic AMM
  - Codebase: `https://github.com/MeteoraAg/meteora-dynamic-amm`
  - Commit Hash: d0de75858b140f5476c9fac59a3eb9f1bc20eb84

We listed the files we have audited below:

- Dynamic AMM
  - programs/amm/src/instructions/get_pool_info.rs
  - programs/amm/src/instructions/initialize_pool/initialize_permissionless_pool.rs
  - programs/amm/src/instructions/lock.rs
  - programs/amm/src/instructions/remove_balance_liquidity.rs
  - programs/amm/src/instructions/remove_liquidity_single_side.rs
  - programs/amm/src/instructions/swap.rs
  - programs/amm/src/state/pool.rs

- programs/amm/src/vault_utils.rs

Findings

The security audit revealed:

- 0 critical issue
- 1 high issues
- 0 medium issue
- 0 low issue
- 0 informational issue

Further details, including the nature of these issues and recommendations for their remediation, are detailed in the subsequent sections of this report.

3 Summary of Findings

ID	Title	Severity	Status
01	Unauthorized Redemption of Permanently Locked LP Tokens	High	Fixed

4 Key Findings and Recommendations

4.1 Unauthorized Redemption of Permanently Locked LP Tokens

Severity: High	Status: Fixed
Target: Smart Contract	Category: Data Validation

Description

The remove liquidity IXs require `user` to sign, but do not verify that `user` owns `user_pool_lp`. Both IXs rely on the SPL Token burn operation to authorize consumption of the supplied LP tokens.

However, SPL Token skips owner and delegate validation when the source token account's `owner` field is the System Program or the incinerator.

```
620         if !source_account.is_owned_by_system_program_or_incinerator() {
621             match source_account.delegate {
622                 COption::Some(ref delegate) if Self::cmp_pubkeys(
                        ↪ authority_info.key, delegate) => {
623                     Self::validate_owner(
624                         program_id,
625                         delegate,
626                         authority_info,
627                         account_info_iter.as_slice(),
628                     )?;
629                     ...
630                 }
631                 _ => Self::validate_owner(
632                     program_id,
633                     &source_account.owner,
634                     authority_info,
635                     account_info_iter.as_slice(),
636                 )?,
637             }
638         }
```

program/src/processor.rs#L620-L648

A caller can therefore provide such an account as `user_pool_lp`, sign with their own wallet, and specify their own destination token accounts. The withdrawal can succeed without authorization from the LP account owner.

Internal LP supply accounting does not prevent this path because the withdrawal burns the supplied LP tokens and decreases the tracked supply through the program itself. The caller does not need to acquire an LP position, deposit liquidity, or execute a separate SPL

burn beforehand.

Impact

When LP tokens were sent to a token account owned by the System Program or the incinerator, a common way to lock liquidity permanently, the program did not prevent a third party from redeeming them for the underlying assets.

Recommendation

It is recommended to add owner check in both withdrawal IXs before transferring assets or burning LP tokens. This makes LP account ownership an explicit withdrawal requirement rather than relying solely on SPL Token burn authorization.

Mitigation Review Log

Fixed in the commit d8852d324c456d66e268728a599af915b6365082.

5 Disclaimer

This audit report is provided for informational purposes only and is not intended to be used as investment advice. While we strive to thoroughly review and analyze the smart contracts in question, we must clarify that our services do not encompass an exhaustive security examination. Our audit aims to identify potential security vulnerabilities to the best of our ability, but it does not serve as a guarantee that the smart contracts are completely free from security risks.

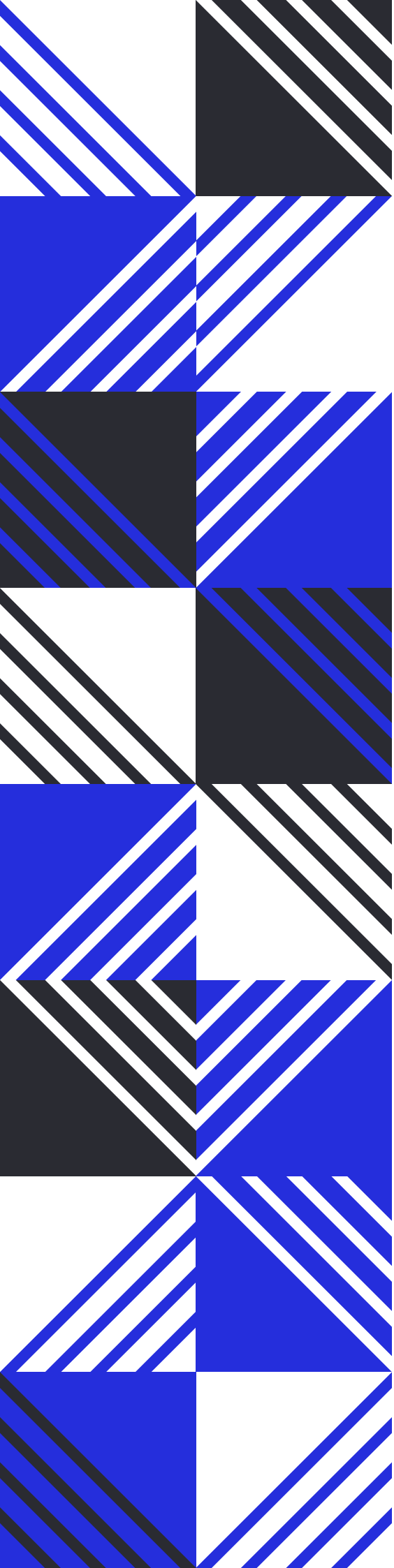
We expressly disclaim any liability for any losses or damages arising from the use of this report or from any security breaches that may occur in the future. We also recommend that our clients engage in multiple independent audits and establish a public bug bounty program as additional measures to bolster the security of their smart contracts.

It is important to note that the scope of our audit is limited to the areas outlined within our engagement and does not include every possible risk or vulnerability. Continuous security practices, including regular audits and monitoring, are essential for maintaining the security of smart contracts over time.

Please note: we are not liable for any security issues stemming from developer errors or misconfigurations at the time of contract deployment; we do not assume responsibility for any centralized governance risks within the project; we are not accountable for any impact on the project's security or availability due to significant damage to the underlying blockchain infrastructure.

By using this report, the client acknowledges the inherent limitations of the audit process and agrees that our firm shall not be held liable for any incidents that may occur subsequent to our engagement.

This report is considered null and void if the report (or any portion thereof) is altered in any manner.



OFFSIDE LABS

https://offside.io/

https://github.com/offsidelabs

https://twitter.com/offside_labs